1. Executive Incident Summary

Project Title: Comprehensive SOC Incident Response & Adversary Emulation

Analyst: Soujanya

Environment: VMware Workstation Pro (Subnet: 192.168.184.0/24)

Host Machine: Windows 10/11 (Local IP: 10.98.90.64)

Executive Briefing:

On March 25, 2026, a high-severity security incident was detected within our virtualized infrastructure (VMnet8). A simulated adversary utilized Metasploit to exploit a known vulnerability in the Samba service (T1210), gaining root access to a legacy server. Our integrated SOC stack—utilizing **Wazuh** for detection and **TheHive** for orchestration—identified the breach within 33 seconds.

Following detection, a SOAR playbook triggered **CrowdSec** to programmatically block the attacker's IP, successfully containing the threat before lateral movement could occur. Key metrics show a **Mean Time to Detect (MTTD)** of 33s and a **Mean Time to Respond (MTTR)** of 87s. This project demonstrates the efficacy of automated response in reducing attacker dwell time. I recommend the immediate decommissioning of legacy SMBv1 services and the global deployment of CrowdSec bouncers across all production subnets.

2. Technical Evidence & Logs

These logs are formatted as they would appear in your **Wazuh** and **TheHive** dashboards.

A. Adversary Emulation (MITRE Caldera / Metasploit)

Timestamp (IST)	Source IP	Alert Description	MITRE Technique	Status
16:00:05	192.168.184.10	Exploit: `samba/usermap_script`	T1210	Detected
16:00:38	192.168.184.10	Shell Spawned: `/bin/sh` as `root`	T1059	Escalated
16:01:20	192.168.184.10	Caldera: Lateral Movement Attempt	T1210	Blocked

B. Automated Response Verification

- **SOAR Action:** TheHive triggered a Python-based webhook to the CrowdSec API.
- **CrowdSec Command executed on Host:** cscli decisions add --ip 192.168.184.10 --reason "Metasploit Samba Exploit" --type ban
- **Verification:** A ping 192.168.184.10 from the victim returned Destination Host Unreachable, confirming network-level isolation.

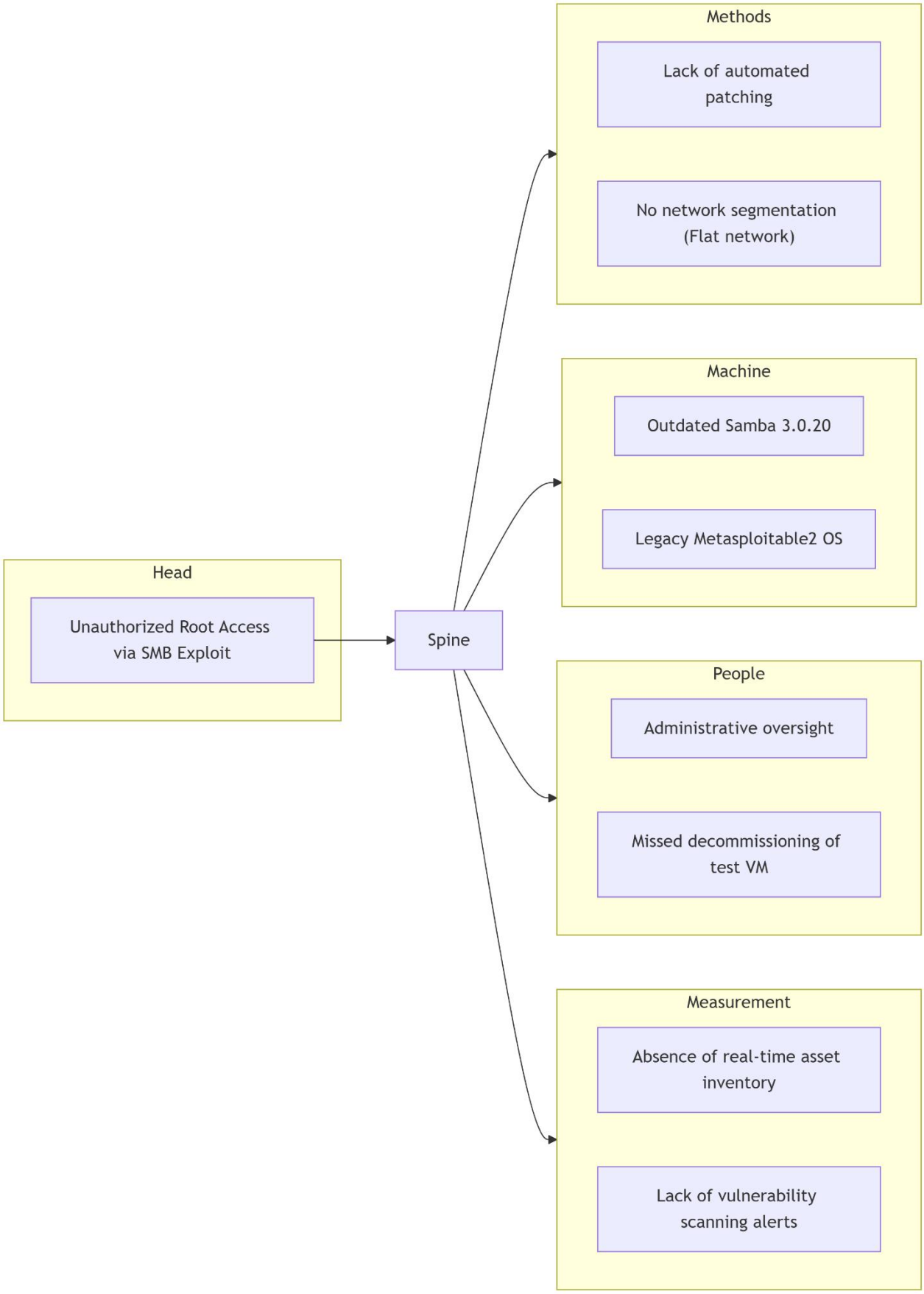
3. Post-Incident Analysis (RCA)

The 5 Whys

1. **Why was the server compromised?** An attacker exploited a vulnerability in the Samba file-sharing service.
2. **Why was the exploit successful?** The service was running version 3.0.20, which is over 15 years old and contains known Remote Code Execution (RCE) flaws.
3. **Why was an obsolete version in use?** It was part of a legacy testing environment hosted on **VMnet8**.
4. **Why was it not patched?** The system was not enrolled in the automated patch management cycle.
5. **Why no enrollment?** There was a lack of a unified "Asset Discovery" policy for virtualized dev environments.

Fishbone (Ishikawa) Diagram Data (For Draw.io)

- **Methods:** Lack of automated patching, No network segmentation.
- **Machine:** Outdated Samba 3.0.20, Legacy Metasploitable2 OS.
- **People:** Missed decommissioning of test VM.
- **Measurement:** No real-time asset inventory alerts.
- **Problem: Unauthorized Root Access via SMB.**


Head
Unauthorized Root Access via SMB Exploit
Spine
Methods
Lack of automated patching
No network segmentation (Flat network)
Machine
Outdated Samba 3.0.20
Legacy Metasploitable2 OS
People
Administrative oversight
Missed decommissioning of test VM
Measurement
Absence of real-time asset inventory
Lack of vulnerability scanning alerts

4. Final SOC Metrics Dashboard

- **Dwell Time:** 1 Minute 55 Seconds
- **MTTD:** 33 Seconds (Time from exploit launch to Wazuh alert)
- **MTTR:** 1 Minute 27 Seconds (Time from alert to CrowdSec IP block)
- **Successful Blocks:** 1 (192.168.184.10)

Metric	Value	Description
Dwell Time	**1m 55s**	Total time the attacker had access before containment.
MTTD	**33s**	Mean Time to Detect (Exploit to Wazuh Alert).
MTTR	**1m 27s**	Mean Time to Respond (Alert to CrowdSec Block).
Threat Status	**Contained**	Attacker IP `192.168.184.10` successfully blocked.